EXERCISE Add a logout button to the Natter UI that sends a DELETE request to the `/sessions` endpoint.

4.7 Summary

- HTTP Basic authentication is awkward for web browser clients with poor UX. You can use token-based authentication to provide a more natural login experience for these clients.
- For web-based clients served from the same site as your API, session cookies are a simple and secure token-based authentication mechanism.
- Session fixation attacks occur if the session cookie doesn't change when a user authenticates. Make sure to always invalidate any existing session before logging the user in.
- CSRF attacks can allow other sites to exploit session cookies to make requests to your API without the user's consent. Use SameSite cookies and the hash-based double-submit cookie pattern to eliminate CSRF attacks.

ANSWERS TO EXERCISES

1. d - The protocol, hostname, and port must all exactly match. The path part of a URI is ignored by the SOP. The default port for HTTP URIs is 80 and is 443 for HTTPS.
2. e - To avoid session fixation attacks you should invalidate any existing session cookie after the user authenticates to ensure that a fresh session is created.